

Plan de Respuesta a Incidentes de Seguridad

Organización: VENMON NATURALMENTE SL **Aplicación:** SellerBrain (sellersbrain.io)
Responsable de seguridad: Fernando Gil — fernando.gil@me.com — +34 665 872 016
Versión: 1.0 · **Fecha de aprobación:** 2026-07-29 · **Próxima revisión:** 2027-01-29 (cada 6 meses)

1. Objetivo y alcance

Definir cómo VENMON NATURALMENTE SL detecta, responde, notifica y documenta los incidentes de seguridad que afecten a la información obtenida de las API de Amazon (SP-API y Amazon Ads API) y a la infraestructura de SellerBrain. Aplica a todos los sistemas que procesan o almacenan dicha información: Cloudflare Workers (backend), Supabase/PostgreSQL en la UE (base de datos), el repositorio de código y las cuentas de acceso asociadas.

2. Roles y responsabilidades

- **Responsable de seguridad (Fernando Gil):** coordina la respuesta, decide la contención, ejecuta las notificaciones y firma el informe posterior. Es el punto de contacto único.
- **Suplente:** en ausencia del responsable, la persona que este designe por escrito.
- Todo el personal con acceso está obligado a comunicar cualquier sospecha de incidente al responsable **de inmediato**.

3. Clasificación de incidentes

Nivel	Ejemplos
Crítico	Fuga o acceso no autorizado a tokens/credenciales de Amazon; exfiltración de datos de la base.
Alto	Acceso no autorizado a una cuenta (Cloudflare, Supabase, Amazon, GitHub); malware confirmado.
Medio	Intento de acceso fallido reiterado; vulnerabilidad explotable detectada sin evidencia de explotación.
Bajo	Errores de configuración sin exposición de datos; phishing recibido y no ejecutado.

4. Detección

Fuentes de detección continua: - **Logs y alertas de Cloudflare** (tráfico anómalo, WAF, errores del Worker). - **Registros de Supabase** (accesos a la base, cambios de rol, consultas anómalas). - **Alertas de acceso** de las cuentas (Amazon, Cloudflare, Supabase, GitHub, correo): inicios de sesión desde ubicaciones o dispositivos nuevos. - Avisos de terceros o de Amazon.

5. Procedimiento de respuesta

1. **Identificar** — confirmar el incidente, su alcance y qué información de Amazon está implicada.
2. **Contener** — cortar el acceso: revocar/rotar los tokens y claves afectados, cerrar sesiones, deshabilitar cuentas o claves comprometidas.
3. **Erradicar** — eliminar la causa (credencial filtrada, configuración insegura, componente vulnerable).
4. **Recuperar** — restaurar el servicio con credenciales nuevas y verificar que no queda acceso residual.

5. **Notificar** — ejecutar las notificaciones de la sección 6 dentro de los plazos.
6. **Documentar** — registrar el incidente (sección 8) con cronología, impacto y acciones.
7. **Revisar** — análisis posterior: causa raíz y medidas para evitar repetición.

6. Notificación de incidentes (plazos)

- **A Amazon:** todo incidente de seguridad que afecte a información de Amazon se comunica a **security@amazon.com dentro de las 24 horas** siguientes a su detección, con la información disponible en ese momento (se amplía después si es necesario).
- **Interna:** al responsable de seguridad de forma inmediata al detectarse.
- **A la autoridad de protección de datos (AEPD) y a los afectados:** si el incidente implicara datos personales (p. ej. datos de contacto de una cuenta de vendedor conectada), se valorará la notificación conforme al RGPD (72 horas a la AEPD cuando proceda). SellerBrain no procesa datos personales de compradores de Amazon (PII).

7. Revisión del plan

Este plan se **revisa como mínimo cada 6 meses** y tras cualquier incidente de nivel Alto o Crítico. Cada revisión actualiza la fecha, la versión y las lecciones aprendidas.

8. Registro de incidentes

Se mantiene un registro con: fecha/hora de detección, descripción, nivel, sistemas y datos afectados, acciones de contención y erradicación, notificaciones realizadas (con fecha/hora), causa raíz y medidas correctoras.

Fecha	Nivel	Descripción	Acciones	Notificado (fecha/hora)	Cierre
—	—	(sin incidentes registrados)	—	—	—

9. Control de versiones

Versión	Fecha	Cambios
1.0	2026-07-29	Versión inicial.